Cybersecurity Act 2 für den Maschinenbau

Was der Vorschlag der Kommission für Ihr Werk, Ihren Einkauf und Ihre Maschinen bedeuten würde

Vorschlag für eine Verordnung des Europäischen Parlaments und des Rates über die Agentur der Europäischen Union für Cybersicherheit (ENISA), den europäischen Rahmen für die Cybersicherheitszertifizierung und die Sicherheit der IKT-Lieferketten sowie zur Aufhebung der Verordnung (EU) 2019/881 (Cybersicherheitsverordnung 2)

Vorschlag der Kommission vom 20. Jan. 2026 (COM(2026) 11). Kein geltendes Recht; der Text kann sich im Verfahren noch ändern.

Für: Arbeitskreis mittelständischer und größerer Unternehmen des Maschinen- und Anlagenbaus

Stand: 13. Nov. 2026

Auf einen Blick

- Jetzt erfassen Sie Lieferanten mit Sitz und Kontrolle und prüfen bei Neukonstruktion und neuen Verträgen Herkunft und Fernzugriff. Einen Umbau bestehender Anlagen verlangt der CSA2 noch nicht.[1]
- Aus dem CSA2 gilt heute nichts, benannt ist niemand; schneller als der übliche Weg ginge ein Verbot gegen einen einzelnen Anbieter. Schon heute gelten NIS-2 (ab mittlerer Größe) und die Meldepflicht des CRA, der übrige CRA ab 11.12.2027; siehe Einordnung.[2]
- Ein Entwurf der Berichterstatterin, nicht des Parlaments, will mehr. Nach dem Entwurf müssten NIS-2-Sektoren, auch Sie, in Kategorien mit EU-Schema nach einer noch offenen Frist nur Zertifiziertes kaufen und einsetzen, ab genug Prüfkapazität.[3]

Fundstellen: [1] Einschätzung: Art. 122, Art. 103(1) · [2] abgeleitet: Art. 122, Art. 100(2), Art. 103(7), Art. 21(2) NIS-2, Art. 2(1) NIS-2, Art. 71(2) CRA · [3] ÄA 66 PE792.222, ÄA 68 PE792.222

Begriffe

Hochrisikoanbieter: Anbieter mit Sitz in einem von der Kommission benannten Drittland oder von dort kontrolliert, auch mit Sitz in der EU, oder ein Anbieter aus einem Drittland oder von dort kontrolliert, den die Kommission einzeln benennt, samt den von ihm kontrollierten Unternehmen.

Wichtige IKT-Assets: Software und Hardware, die die Kommission per Durchführungsrechtsakt als besonders kritisch ermittelt, auch in der Produktion. Für Telekommunikationsnetze legt der Vorschlag sie in Anhang II fest.

Durchführungsrechtsakt: Rechtsakt der Kommission im Prüfverfahren mit einem Ausschuss der Mitgliedstaaten. Erst er macht ein Verbot verbindlich.

Entwürfe: Der Berichtsentwurf ist der Text der Berichterstatterin, ein Kompromisstext der des Ratsvorsitzes. Keiner ist die Position von Parlament oder Rat. Zahlen in eckigen Klammern wie [24] sind noch offen.

Kürzel der Fundstellen: ÄA Änderungsantrag, EG Erwägungsgrund, PE792.222 Berichtsentwurf, WK Kompromisstext des Ratsvorsitzes, MVO Maschinenverordnung.

Bin ich betroffen?

Frage	Antwort
Gelten die Regeln zur Lieferkette auch für Ihre Firma? [1]	Ja, nach dem Vorschlag fällt jeder Maschinenbauer darunter, auch kleine. Pflichten entstehen erst durch Beschlüsse der Kommission, die sie auf größere Firmen begrenzen kann.
Was in Ihrem Werk kann es treffen? [2]	Teile von Hochrisikoanbietern, vor allem in Anlagen, die die Kommission als besonders kritisch einstuft.
Betrifft es die Maschinen, die Sie liefern? [3]	Nur wenn Elektronik oder Software eines Hochrisikoanbieters darin steckt. Ein Verbot träfe dann Ihren Kunden.
Kann ein Lieferant oder Ihre Firma Hochrisikoanbieter sein, auch mit Sitz in der EU? [4]	Ja, wenn sie aus einem Drittland gesteuert wird und die Kommission dieses Land, die Firma oder ihren Mutterkonzern benennt.
Betrifft es Ihre Kunden? [5]	Ja. Kunden in Energie, Verkehr, Wasser, Chemie, Pharma, Lebensmitteln und Fahrzeugbau fallen ab 50 Beschäftigten unter NIS-2, unter den Vorschlag auch kleinere. Der Berichtsentwurf will, dass sie Zertifiziertes kaufen.
Gibt es schon eine Liste der Produkte, die betroffen sein können? [6]	Im Vorschlag und beim Ratsvorsitz nur Telekommunikationsnetze. Der Berichtsentwurf nimmt etwa Windräder samt Steuerung auf und nennt Funkmodule zur vorrangigen Prüfung. Nichts davon ist Recht.

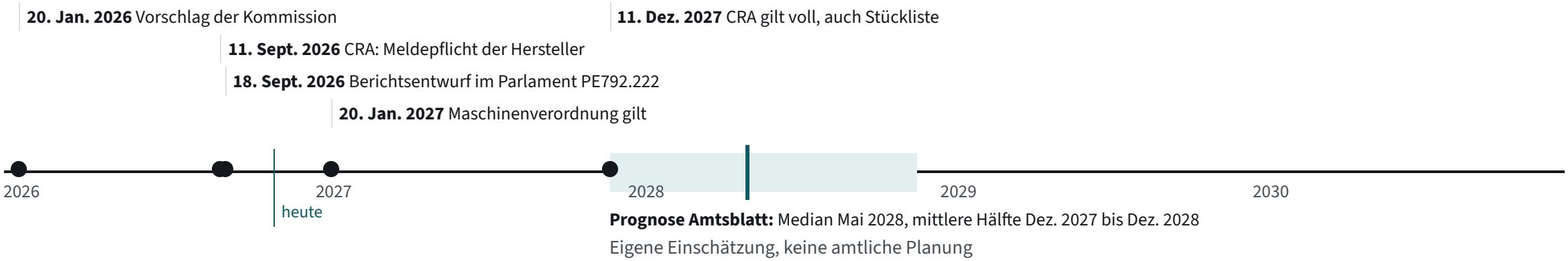
Fundstellen: [1] abgeleitet: Art. 1(3), Art. 103(8), Anhang II NIS-2 · [2] abgeleitet: Art. 2(35), Art. 102(1), Art. 103(2), Art. 103(7) · [3] abgeleitet: Art. 103(1), Art. 2(33), Art. 103(7) · [4] abgeleitet: Art. 2(39), Art. 2(37), EG 138, Art. 100(2), Art. 103(6) · [5] abgeleitet: Anhang I NIS-2, Anhang II NIS-2, Art. 2(1) NIS-2, Art. 1(3), ÄA 66 PE792.222, ÄA 68 PE792.222 · [6] Art. 110(1), Anhang II, Art. 110(1) WK 14487/26 ADD 1, Anhang II WK 14487/26 ADD 1, ÄA 159 PE792.222, ÄA 160 PE792.222, ÄA 107 PE792.222

Vorgeschlagene Pflichten

Rolle	Pflicht	Ab wann	Prozess
Werk (Sie als Einrichtung)[1]	Keine IKT-Komponenten von Hochrisikoanbietern in wichtigen IKT-Assets; Auflagen wie Fernzugriff abschalten	Erst mit Durchführungsrechtsakt, mit Übergangs- und Auslauffristen	IT/OT der Produktion, Einkauf
Werk (Sie als Einrichtung)[2]	Der Behörde auf Anfrage Lieferanten und die Zusammensetzung von Hard- und Software maschinenlesbar nennen	Sobald der CSA2 gilt; ob schon vor einem Durchführungsrechtsakt, ist offen	IT/OT der Produktion, Einkauf
Auskunft über Sitz und Kontrolle (Sie als Lieferant)[3]	Auf Anfrage der Kommission Sitz, Eigentum und Kontrolle fristgerecht nennen, sonst droht Einstufung	Nur wenn die Kommission Sie vorab als möglicherweise in einem benannten Drittland ansässig, von dort oder von einem einzeln benannten Anbieter kontrolliert ermittelt; Anhörung vor Einstufung	Geschäftsführung, Vertrieb

Fundstellen: [1] Art. 103(1), Art. 103(2) · [2] abgeleitet: Art. 114(2), Art. 103(2) · [3] Art. 104(2), Art. 104(4), Art. 104(5)

Allgemeines Verbot im Werk kaum vor 2030 (unsere Schätzung), die CRA-Frist 11.12.2027 kommt vorher



Danach, Daten offen:

1. Inkrafttreten Tag offen; ein späterer Geltungsbeginn ist nicht vorgesehen
2. Verbot gegen einen einzelnen Anbieter Ab Inkrafttreten möglich, per Durchführungsrechtsakt nach Anhörung der Mitgliedstaaten und betroffener Einrichtungen; ohne Risikobewertung, Auslauffrist nur, wo nötig (abgeleitet)
3. Risikobewertung durch die NIS-Kooperationsgruppe Auf Antrag, binnen 6 Monaten; beim Ratsvorsitz bis 12 Monate
4. Durchführungsrechtsakte können Assets ermitteln und Teile verbieten Ohne Frist, im Prüfverfahren mit dem Ausschuss der Mitgliedstaaten
5. Übergangs-, dann Auslauffrist Länge im Rechtsakt beziffert nur für Mobilfunk: höchstens 36 Monate ab der Liste
6. Verbot im Werk, nach unserer Schätzung (Eigenübung)

Was jetzt zu tun ist

Bereich	Schritt	Wer	Bis wann	Aufwand
Geschäftsleitung[1]	Klären Sie, ob jemand außerhalb der EU Sie kontrolliert, auch über Gesellschafter oder Geschäftsleitung dort.	Geschäftsführung, ggf. externe Beratung	jetzt	klein (Schätzung)
Einkauf, neue Verträge[2]	Fragen Sie nach Sitz, Mutterkonzern, Kontrolle über Firmware und Funk und Fernzugriff; Meldung bei Kontrollwechsel.	Einkauf	bei jedem neuen Rahmenvertrag, ab jetzt	mittel (Schätzung)
Entwicklung, Neukonstruktion[3]	Wählen Sie Steuerungen, Funk- und Fernwartungsmodule so, dass ein Lieferantenwechsel möglich bleibt.	Entwicklung, Einkauf	bei der nächsten Neukonstruktion	mittel (Schätzung)
Produktkonformität, Einkauf[4]	Erstellen Sie die CRA-Software-Stückliste und eine Hardware-Stückliste. Sitz, Mutterkonzern und Kontrolle führen Sie im Lieferantenstamm, verknüpft mit der Stückliste.	Produktkonformität, Entwicklung, Einkauf	bis 11.12.2027 (CRA)	mittel (Schätzung)
Vertrieb, Kundenverträge[5]	Regeln Sie in neuen Kundenverträgen, wer einen behördlich verlangten Austausch von Komponenten zahlt.	Geschäftsführung, Vertrieb, ggf. externe Beratung	bei jedem neuen Kundenvertrag, ab jetzt	klein (Schätzung)
IT/OT im Werk, Bestand[6]	Erfassen Sie OT und Fernzugänge Ihrer Werke mit Anbietern. Kein Umbau verlangt; Ersatz bei fälliger Erneuerung.	Werksleitung, IT/OT	Liste jetzt, Ersatz bei fälliger Erneuerung	mittel (Schätzung)

Fundstellen: [1] abgeleitet: Art. 2(37)-(39), EG 138, Art. 104(4) · [2] abgeleitet: Art. 103(1), Art. 103(2) · [3] Einschätzung: Art. 103(1), Art. 2(33) · [4] Einschätzung: Anhang I, Teil II CRA, Art. 3(39) CRA, Art. 71(2) CRA, Art. 114(2) · [5] Einschätzung: Art. 103(1), ÄA 142 PE792.222 · [6] Einschätzung: Art. 103(1), Art. 21(2) NIS-2

Offene Fragen

- Gilt der Teil zur Lieferkette auch unterhalb der NIS-2-Größenschwelle? Nach dem Wortlaut ja; ein Durchführungsrechtsakt kann ihn nach Größe begrenzen.
- Wird Hochrisikoanbieter, wer aus einem benannten Land kommt, oder nur, wer einzeln geprüft wurde? Der Rat hat den Text des Vorsitzes dazu nur teilweise freigegeben.
- Kommt die Kaufpflicht des Berichtsentwurfs, und ab wann? Die Frist [24] ist offen, sie gilt erst ab bestätigter Prüfkapazität, und ob „einsetzen“ auch vorhandene Anlagen trifft, lässt der Entwurf offen.
- Wird Industrieautomation Gegenstand einer Risikobewertung oder eines EU-Schemas, etwa für Anhang III Nr. 1.1.9 und 1.2.1 MVO? Uns ist beides nicht bekannt.
- Wer trägt die Kosten, wenn Komponenten in laufenden Anlagen ersetzt werden müssen? Der Vorschlag verlangt eine Folgenabschätzung, nur der Berichtsentwurf sieht Entschädigung vor.
- Können Behörden Lieferantenlisten schon ab Inkrafttreten verlangen oder erst nach einem Durchführungsrechtsakt? Die Texte lassen beides zu.

Modul Einordnung

Was für Sie gilt oder bald gilt, unabhängig von diesem Rechtsakt

Was für Sie gilt oder bald gilt

Rechtsakt	Was gilt	Ab wann
CRA und NIS-2/BSIG[1]	Je binnen 24 und 72 Stunden: ausgenutzte Schwachstellen und schwere Vorfälle Ihrer Produkte (CRA, auch ältere Maschinen) und als wichtige Einrichtung erhebliche Vorfälle im eigenen Betrieb (§ 32 BSIG).	CRA seit 11.9.2026; BSIG ab Einrichtung des Meldewegs
NIS-2 und BSIG[2]	Maschinenbau ab 50 Beschäftigten oder je über 10 Mio. € Umsatz und Bilanzsumme ist wichtige Einrichtung: beim BSI registrieren, Risikomaßnahmen samt Sicherheit der Lieferkette treffen (§§ 28, 30, 33 BSIG).	heute; Registrierfrist für schon erfasste Unternehmen am 6.3.2026 abgelaufen
NIS-2 und BSIG[3]	Die Geschäftsleitung setzt die Risikomaßnahmen um, überwacht sie, wird geschult und haftet der Einrichtung (§ 38 BSIG). Bußgeld bis 7 Mio. €, über 500 Mio. € Gruppenumsatz bis 1,4 % (§ 65 BSIG), gegen das Unternehmen oder gegen Personen.	heute
BSIG § 41[4]	Das BMI kann Betreibern kritischer Anlagen den Einsatz kritischer Komponenten untersagen, wenn er die öffentliche Ordnung oder Sicherheit voraussichtlich beeinträchtigt; dabei zählt etwa, ob die Regierung eines Drittstaats den Hersteller kontrolliert.	heute, nur bei Kunden, die Betreiber kritischer Anlagen sind
Funkanlagen (RED)[5]	Funkanlagen, die direkt oder über andere Geräte über das Internet kommunizieren können, dürfen dem Netz nicht schaden (Art. 3(3)(d) RED), bei Personendaten schützen sie diese.	seit 1.8.2025 bis 10.12.2027
Maschinenverordnung[6]	Jede Maschine, die ab 20.1.2027 in Verkehr kommt, auch aus laufender Serie, gegen Korrumpierung schützen, sicherheitsrelevante Software kenntlich machen, Eingriffe aufzeichnen (Anh. III 1.1.9, 1.2.1).	ab 20.1.2027
CRA[7]	Produkte mit digitalen Elementen, die ab 11.12.2027 in Verkehr kommen, auch aus laufender Serie: Anhang I erfüllen (Stückliste, Updates), Konformität bewerten und erklären, CE; meist interne Kontrolle.	ab 11.12.2027
CRA[8]	Zugekaufte Komponenten mit Datenverbindung, die ab 11.12.2027 in Verkehr kommen, tragen CE nach CRA, mit Konformitätserklärung und angegebenem Supportende; Sie prüfen sie beim Einbau mit Sorgfalt.	ab 11.12.2027

Fundstellen: [1] Art. 14 CRA, Art. 69(3) CRA, Art. 33(4) NIS-2, Anhang II NIS-2, Art. 23(1), (4) NIS-2, Art. 3(8), Art. 3(39) NIS-2, Art. 21(2), Art. 2 abgeleitet: Art. 14(1) CRA, Art. 20(2), Art. 6, Art. 64(3) NIS-2 · abgeleitet · [5] abgeleitet: Art. 1 Abs. 2 RED 2022/30, Art. 1 Delegated Regulation 2023/2444, Art. 1 Delegated Regulation 2026/339, EG 5 Delegated Regulation 2026/339 · [6] abgeleitet: Anhang III MVO, Art. 54 MVO, Art. 52(1) MVO · [7] abgeleitet: Anhang I, Teil II CRA, Art. 13(8) CRA, Art. 69(2) CRA, Art. 71(2) CRA, Art. 32(1) CRA, Art. 32(2) CRA, Art. 7(1) CRA, Art. 28 CRA, Art. 30 CRA · [8] abgeleitet: Art. 13(5) CRA, Art. 13(19) CRA, Art. 28 CRA, Art. 30 CRA, Art. 2(1) CRA

Modul Geschäftsführung

Ein Beispiel und was Sie morgen Ihrem Team sagen

Beispiel: Fernwartungs-Gateway eines Anbieters mit Mutterkonzern außerhalb der EU beim Lebensmittelkunden

Schritt	Was passiert
Heute[1]	Ihre Anlage beim Lebensmittelhersteller hat ein Gateway eines Anbieters mit Mutterkonzern im Drittland. Nichts ist verboten. Wann? Heute.
CSA2 gilt[2]	Die Behörde kann vom Kunden Lieferanten und Aufbau der Anlage verlangen; der Kunde fragt Sie nach Herkunft und Fernzugriff. Wann? Nach unserer Schätzung ab 2028.
Risikobewertung[3]	Drei Mitgliedstaaten oder die Kommission beantragen eine Bewertung, etwa der Fernwartung in der Produktion. Wann? Nach unserer Schätzung eher 2029, bei frühem Gesetz schon 2028.
Durchführungsrechtsakte[4]	Die Kommission benennt das Drittland, ermittelt solche Gateways als wichtige IKT-Assets und verbietet Hochrisiko-Teile darin. Wann? Nach unserer Schätzung 2029 bis 2030.
Liste und Auslauf[5]	Die Liste nennt den Anbieter. Bis zum Ende der Auslauffrist muss der Kunde das Gateway ersetzen; wer zahlt, regelt der Vorschlag nicht. Wann? Nach unserer Schätzung nach 2030.
Was Sie jetzt tun[6]	Sie regeln in neuen Kundenverträgen, wer einen verlangten Austausch zahlt, und planen für neue Anlagen ein Gateway mit Ersatzlieferant. Wann? Jetzt.

Fundstellen: [1] abgeleitet: Art. 122, Anhang II NIS-2 · [2] Einschätzung: Art. 114(2) · [3] Einschätzung: Art. 99(1)-(2) · [4] Einschätzung: Art. 100(2), Art. 102(1), Art. 103(1) · [5] Einschätzung: Art. 104(1), Art. 103(1), ÄA 142 PE792.222 · [6] Einschätzung: Art. 103(4), Art. 103(1)

Was sage ich morgen meinem Team?

- Der CSA2 ist ein Vorschlag. Austauschen müssen wir nach ihm heute nichts, aber wir klären, wer uns kontrolliert und von wem unsere IKT-Teile stammen.[1]
- Bei jeder Neukonstruktion und jedem neuen Rahmenvertrag fragen wir nach Sitz, Mutterkonzern und Fernzugriff des Lieferanten und halten einen Wechsel offen.[2]
- Für Maschinen mit digitalen Elementen brauchen wir die Software-Stückliste nach dem CRA ohnehin ab 11.12.2027; sie hilft auch, wenn Kunden nach Herkunft fragen.[3]
- Ein eigenes CSA2-Budget planen wir nicht. Geld und Verantwortung gehen in die CRA-Stückliste (Produktkonformität) und die Lieferantenangaben (Einkauf).[4]

Fundstellen: [1] Einschätzung: Art. 103(1), Art. 2(39) · [2] Einschätzung: Art. 103(1) · [3] abgeleitet: Anhang I, Teil II CRA, Art. 71(2) CRA · [4] Einschätzung: Art. 103(1)

Modul Produktkonformität

Was für Hersteller neu ist, neben anderen Rechtsakten, was noch streitig ist

Was für Hersteller neu ist

ENISA soll die Mitgliedstaaten auch operativ unterstützen und betreibt die Meldeplattform des CRA weiter. Zertifizierung soll schneller werden, und neue EU-Regeln sollen Lieferketten vor Hochrisikoanbietern schützen. Der Vorschlag hebt auf: Cybersecurity Act.

Thema	Heute	Künftig
Produktpflichten[1]	CRA und Maschinenverordnung regeln Anforderungen, Bewertung und Unterlagen Ihrer Maschine	Keine neue Pflicht für Ihre Maschine, solange Sie kein EU-Zertifikat halten; CRA und Maschinenverordnung bleiben unverändert
Indirekt über Ihre Kunden[2]	Kunden fragen nach Lieferanten, wenn sie selbst wollen oder NIS-2 sie dazu bringt	Kunden müssten der Behörde auf Anfrage Lieferanten und Zusammensetzung nennen; sie fragen dann Sie
Komponenten-Zertifikat (Entwurf)[3]	Zertifizierung ist freiwillig	Nach dem Berichtsentwurf bräuchten IKT-Teile in wichtigen IKT-Assets 36 Monate nach einem Schema ein Zertifikat
Bestehende EU-Zertifikate (EUCC)[4]	EUCC ist das einzige Schema nach der VO 2019/881	Keine ausdrückliche Übergangsregel; Verweise auf alte Schemata gelten als Verweise auf den CSA2
Weg zum Schema[5]	ENISA erstellt Schemaentwürfe ohne feste Frist.	Entwurf binnen 12 Monaten, Prüfung für Stufe „hoch“ im EWR, beides wenn nichts anderes gilt
Zertifizierung[6]	Freiwillig, für IKT-Produkte, -Dienste, -Prozesse, seit 2025 auch verwaltete Sicherheitsdienste	Weiter freiwillig. Neu ist ein Zertifikat für die Cyberabwehr einer Einrichtung.

Fundstellen: [1] abgeleitet: Art. 121(1), Art. 98(2) · [2] abgeleitet: Art. 114(2), Art. 21(2) NIS-2 · [3] Art. 56(2) CSA, ÄA 65 PE792.222, ÄA 68 PE792.222 · [4] abgeleitet: EG 169, Art. 121(2), Art. 86(3) · [5] Art. 49 CSA, Art. 74(1), Art. 82(7)-(8) · [6] Art. 56(2) CSA, Art. 1 CSA amendment 2025/37, Art. 71(2)-(3)

Pflichten im Einzelnen

Rolle	Pflicht	Ab wann	Prozess
Besteht: Inhaber eines EU-Zertifikats (freiwillig)[1]	Später entdeckte Schwachstellen und Abweichungen der Konformitätsbewertungsstelle melden, die das Zertifikat ausgestellt hat	Seit 2019 nach dem CSA; der Vorschlag führt es fort	Entwicklung/Produkt
Neu: Inhaber eines EU-Zertifikats[2]	Keine Hochrisiko-Teile in zertifizierten wichtigen IKT-Assets; Zusatzinfos 5 Jahre nach Zertifikatsende	Mit dem CSA2; das Verbot erst, wenn Assets ermittelt und Anbieter benannt sind	Entwicklung/Produkt
Neu: Ihr Werk als Einrichtung (Nutzer), bei Verstoß[3]	Bußgeld bis 7 % des Gruppenumsatzes bei Nutzungsverbot, bis 1 % bei Transparenz-, bis 2 % bei anderen Auflagen	Erst wenn ein Verbot oder eine Auflage per Durchführungsrechtsakt gilt	Compliance, IT/OT der Produktion

Fundstellen: [1] Art. 56(8) CSA, Art. 85(8) · [2] Art. 85(9), Art. 84(3), Art. 55(2) CSA · [3] Art. 115(5), Art. 115(6), Art. 115(7)

Neben CRA, NIS-2 und Maschinenverordnung

Thema	Heute schon	Neu durch den Vorschlag	Bewertung
Drei ähnliche Begriffe[1]	Wichtige Produkte sind Kategorien des Anhangs III CRA, wichtige Einrichtungen Unternehmen nach NIS-2	Wichtige IKT-Assets sind Anlagen eines Betreibers, die die Kommission ermittelt	neu
Normen, der übliche Weg zur Vermutung[2]	Vermutung über harmonisierte Normen im Amtsblatt (Art. 20(1) MVO, Art. 27(1) CRA); in Arbeit u. a. EN 50742 und die Reihe EN 40000 (nur teils zur Zitierung)	Der Vorschlag ändert daran nichts; Zertifikate nach einem Schema blieben ein zweiter, freiwilliger Weg	gleich
Zertifikat als Nachweis (MVO, CRA)[3]	Zertifikat nach VO 2019/881 begründet Vermutung, soweit es abdeckt: MVO ab 20.1.2027 für Anh. III 1.1.9, 1.2.1; CRA für Anhang I	Die Verweise gälten für Schemata des CSA2; ein Schema für 1.1.9 und 1.2.1 ist uns nicht bekannt	gleich
Sicherheit der Lieferkette (NIS-2)[4]	Sicherheit der Lieferkette und Beachtung koordinierter Risikobewertungen, für wesentliche und wichtige Einrichtungen	EU-Verbote und Auflagen für Komponenten von Hochrisikoanbietern in wichtigen IKT-Assets	zusätzlich
Stückliste und Auskunft[5]	Software-Stückliste des Herstellers, mindestens oberste Abhängigkeiten, ab 11.12.2027 (Anhang I Teil II CRA)	Behörde kann vom Betreiber Hard- und Software samt aller Abhängigkeiten maschinenlesbar verlangen	zusätzlich
Zertifikat für das Unternehmen[6]	Mitgliedstaaten können zertifizierte Produkte vorschreiben, delegierte Rechtsakte Zertifikate (Art. 24 NIS-2)	Vorschlag COM(2026) 13 ließe Mitgliedstaaten von wesentlichen und wichtigen Einrichtungen Cyberabwehr-Zertifikate verlangen	zusätzlich

Fundstellen: [1] Art. 7(1) CRA, Art. 3(2) NIS-2, Art. 2(35) · [2] abgeleitet: Art. 20(1) MVO, Art. 27(1) CRA · [3] abgeleitet: Art. 20(9) MVO, Art. 54 MVO, Art. 8(1) CRA, Art. 27(8) CRA, Art. 121(2), Art. 80(3) · [4] Art. 21(2)-(3) NIS-2, Art. 98(2), Art. 103(1)-(2) · [5] abgeleitet: Anhang I, Teil II CRA, Art. 71(2) CRA, Art. 114(2) · [6] Art. 24(1)-(2) NIS-2, Art. 71(2), Art. 1 NIS-2-Änderung

Was noch streitig ist

Thema	Kommission	Berichtsentwurf PE792.222	Ratsvorsitz, öffentliche Texte bis Sept. 2026
Wer ist Hochrisikoanbieter?[1]	Anbieter mit Sitz in oder Kontrolle aus einem benannten Drittland, dazu einzeln benannte	Prüft jeden Anbieter einzeln mit einer Matrix; das Länderrisiko bleibt ein Kriterium	Behält Anbieter aus benannten Drittländern; Länder- und Einzelbenennung sind geschwärzt
Zertifizierung freiwillig oder Pflicht?[2]	Freiwillig, außer Unions- oder nationales Recht schreibt sie vor	Pflicht als Regel; nach [24] Monaten in Kategorien mit Schema nur Zertifiziertes kaufen und einsetzen, ab Prüfkapazität	Bleibt freiwillig, außer Recht schreibt sie ausdrücklich vor
Zertifikat für Komponenten?[3]	Keine Pflicht	Stufe „mittel“ oder „hoch“ in wichtigen IKT-Assets, 36 Monate nach Verfügbarkeit eines Schemas; KMU 12 Monate später	Keine solche Pflicht
Zertifikat als Nachweis für CRA und NIS-2[4]	Konformitätsvermutung nur, wo ein anderes Gesetz es vorsieht	Bei Stufe „mittel“ oder „hoch“ Vermutung für Art. 21(2) NIS-2 und die Anforderungen des CRA	Absatz 1 unverändert; für die Vermutung prüft eine nach der Verordnung notifizierte Konformitätsbewertungsstelle
Welche Anlagen sind wichtige IKT-Assets?[5]	Per Durchführungsrechtsakt; Anhang II nur Telekommunikation. Fernzugriff abschalten ist als Auflage möglich	Anhang II auch netzgekoppelte Erzeugung und Speicher samt SCADA und Wechselrichtern; IoT-Module, Krane zur Prüfung	Kommission muss ermitteln, wenn die Bewertung Risiken zeigt; Bewertung bis 12 Monate

Fundstellen: [1] Art. 2(39), Art. 100(1)-(2), ÄA 28 PE792.222, ÄA 98 PE792.222, ÄA 162 PE792.222, Art. 2(39) WK 14487/26 ADD 1, Art. 100 WK 14487/26 ADD 1, Art. 102a WK 14487/26 ADD 1 · [2] Art. 71(3), ÄA 63 PE792.222, ÄA 66 PE792.222, ÄA 68 PE792.222, Art. 71(3) WK 13671/26 · [3] Art. 71(3), ÄA 65 PE792.222, ÄA 68 PE792.222, Art. 71(3) WK 13671/26 · [4] Art. 78(1), ÄA 77 PE792.222, Art. 78(2) WK 13671/26 · [5] Art. 102(1), Anhang II, Art. 103(2), ÄA 159 PE792.222, ÄA 160 PE792.222, ÄA 108 PE792.222, Art. 99(2) WK 14487/26 ADD 1, Art. 102(1) WK 14487/26 ADD 1

Modul Einkauf

Fragen an Lieferanten, Teile, Vertrag, Kosten, Antwort an Kunden

Für den Einkauf

Was	Inhalt
Frage an Lieferanten[1]	Wo ist Ihr Sitz, wer ist Ihr Mutterkonzern, wer kontrolliert Sie? Wer kontrolliert Firmware und Funkmodule? Über welchen Weg und von wo läuft der Fernzugriff?
Wann liegt Kontrolle vor?[2]	Bei bestimmendem Einfluss, auch über Zwischengesellschaften oder eine Geschäftsleitung im Drittland; eine Prozentschwelle gibt es nicht. Erbitten Sie Konzernaufbau, Gesellschafter und Stimmrechte.
Fertigungsland ist nicht der Maßstab[3]	Es zählen Sitz und Kontrolle. Ein EU-Händler eines Drittlandherstellers kann Teile eines Hochrisikoanbieters liefern, ein deutscher Hersteller, den ein Drittlandkonzern kontrolliert, selbst einer sein.
Teile, in dieser Reihenfolge[4]	Zuerst Fernwartung und Funk (Gateways, Router, Mobilfunkmodule), dann Steuerungen und Antriebe mit Firmware, dann Kameras und Software mit Update-Zugang.
Erwägungsgrund 160: Entlastung nur bei der Kontrolle[5]	Nach einem Erwägungsgrund müssen Sie nicht selbst prüfen, ob ein Lieferant fremd kontrolliert ist, und dürfen sich auf die Behörden verlassen. Von wem Ihre IKT-Teile stammen, sollten Sie trotzdem wissen.

Fundstellen: [1] abgeleitet: Art. 2(37)-(39), Art. 103(2), Art. 114(2) · [2] abgeleitet: Art. 2(37), EG 138 · [3] abgeleitet: Art. 2(37)-(39), Art. 103(1), Art. 100(2) · [4] Einschätzung: Art. 2(33), Art. 103(2), ÄA 108 PE792.222, ÄA 160 PE792.222 · [5] abgeleitet: EG 160, Art. 103(1), Art. 114(2)

Vertrag, Kosten und Kunden

Unsere Einschätzung, keine Rechtsberatung. Was ein Vertrag regeln sollte.

Was	Vorschlag
Klauselidee A, kein Muster[1]	Meldung eines Wechsels von Sitz oder Kontrolle; Sonderkündigung bei behördlichem Verbot; Kosten für Ersatz, Aus- und Einbau, Anpassung, erneute Konformitätsbewertung und Inbetriebnahme beim Lieferanten
Klauselidee B, kein Muster[2]	Teilung der Kosten des Austauschs (hälftig oder nach Restabschreibung); Kündigung der betroffenen Teile ohne Entschädigung
Kostenverteilung heute[3]	Kein Text regelt, wer zwischen Lieferant, Ihnen und Kunde zahlt; Entschädigung nur im Berichtsentwurf, für den Kunden
Satz für Kunden[4]	Auskunft an Kunden unter Vertraulichkeit: IKT-Komponenten, deren Lieferanten mit Sitz und Mutterkonzern, Fernwartungswege; Fertigungsland getrennt
Wenn ein Lieferant nicht antwortet[5]	Einmal schriftlich nachfragen und vermerken; bei Neukonstruktion das Teil als ungeklärt behandeln und eine Alternative einplanen
Laufende Rahmenverträge[6]	Kein vorzeitiger Umbau; Meldepflicht und Kostenregel bei der nächsten Vertragsänderung aufnehmen; Verträge über 2029 hinaus früher nachverhandeln

Fundstellen: [1] Einschätzung: Art. 2(39), Art. 103(1), Art. 103(2), Art. 3(30) CRA, Art. 3(16) MVO · [2] Einschätzung: Art. 103(1), ÄA 142 PE792.222 · [3] abgeleitet: Art. 103(4), ÄA 142 PE792.222 · [4] Einschätzung: Art. 114(2), Art. 114(6), Art. 2(39) · [5] Einschätzung: Art. 104(4) · [6] Einschätzung: Art. 103(1)

Anhang

Zum Nachschlagen: Verfahren, andere Rechtsakte, Leitlinien und Normen, Quellen

Wo steht das Verfahren?

	Stand
Parlament	Berichtsentwurf vom 18. Sept. 2026, Abstimmung im Ausschuss steht aus. Federführend ITRE, Berichterstattung Markéta Gregorová
Rat	Ratsarbeitsgruppe, letztes Dokument vom 12. Nov. 2026. Die Arbeitsgruppe hat 25-mal getagt, zuletzt am 5. Nov. 2026
Nächste Schritte	Parlament: Änderungsanträge und Abstimmung im Ausschuss. Rat: Arbeitsgruppe bis zum Mandat. Danach Trilog-Verhandlungen

Öffentliche Texte bisher: 8. Sept. 2026: Kompromisstext des Ratsvorsitzes WK 13671/26; 10. Sept. 2026: Arbeitsdokument des Rates WK 13885/26; 14. Sept. 2026: Arbeitsdokument des Rates WK 13973/26; 18. Sept. 2026: Berichtsentwurf im Parlament PE792.222; 21. Sept. 2026: Kompromisstext des Ratsvorsitzes WK 14487/26 ADD 1; 22. Sept. 2026: Arbeitsdokument des Rates WK 14500/26

Andere Rechtsakte

Rechtsakt	Stand	Beziehung	Relevanz Maschinen- und Anlagenbau
Cybersecurity Act	in Kraft	wird aufgehoben	mittel
NIS-2-Änderung	Vorschlag der Kommission, kein geltendes Recht	im Zusammenhang	nicht bewertet
NIS 2 Directive	in Kraft	im Zusammenhang	hoch
Cyber Resilience Act	in Kraft	im Zusammenhang	hoch
Industrial Accelerator Act	Vorschlag der Kommission, kein geltendes Recht	im Zusammenhang	mittel
Net Zero Industry Act	anwendbar	im Zusammenhang	niedrig
Vergabe-Rechtsakt (PPA)	Vorschlag der Kommission, kein geltendes Recht	im Zusammenhang	mittel
Cloud and AI Development Act	Vorschlag der Kommission, kein geltendes Recht	im Zusammenhang	nicht bewertet

Leitlinien und Umsetzung

Art	Titel	Stand
Initiative der Kommission (Have your say)	The EU Cybersecurity Act	Vorschlag veröffentlicht, auf Have your say am 5. Feb. 2026
Leitlinie (unverbindlich), zu Cybersecurity Act	EUCC Guidelines on CSP-based evaluation in the context of Secure Elements (European Union Agency for Cybersecurity (ENISA))	4. Nov. 2026
Leitlinie (unverbindlich), zu Cybersecurity Act	ENISA Secure by Design and Default Playbook (European Union Agency for Cybersecurity (ENISA))	30. Juli 2026
Leitlinie (unverbindlich)	Draft candidate EUMSS Scheme v1.1 for Public Review (European Union Agency for Cybersecurity (ENISA))	24. Juli 2026
Leitlinie (unverbindlich), zu Cybersecurity Act	EUCC Guidelines on Cryptography (European Union Agency for Cybersecurity (ENISA))	30. Juni 2026
Leitlinie (unverbindlich), zu Cybersecurity Act	ENISA NIS360 (European Union Agency for Cybersecurity (ENISA))	28. Mai 2026

Quellen und weiterlesen

- **Vorschlag der Kommission (EUR-Lex)**
  https://eur-lex.europa.eu/legal-content/DE/TXT/?uri=CELEX:52026PC0011
- **Legislative Observatory des Parlaments**
  https://oeil.europarl.europa.eu/oeil/en/procedure-file?reference=2026/0011%28COD%29
- **Seite des Rechtsakts (EU regulation timeline)**
  https://git-z0man.github.io/eu-regulation-timeline/acts/csa2.html
- **Verfahrensseite (EU regulation timeline)**
  https://git-z0man.github.io/eu-regulation-timeline/procedures/csa2.html
- **Fortschrittsbericht (Rat) ST 9399/26, 22. Mai 2026**
  https://data.consilium.europa.eu/doc/document/ST-9399-2026-INIT/de/pdf
- **Kompromisstext des Ratsvorsitzes WK 11263/26, 7. Aug. 2026**
  https://data.consilium.europa.eu/doc/document/WK-11263-2026-INIT/en/pdf
- **Kompromisstext des Ratsvorsitzes WK 13671/26, 8. Sept. 2026**
  https://data.consilium.europa.eu/doc/document/WK-13671-2026-INIT/en/pdf
- **Berichtsentwurf im Parlament PE792.222, 18. Sept. 2026**
  https://data.europarl.europa.eu/distribution/reds_iCmRp-Dft/ITRE-PR-792222/ITRE-PR-792222_de.docx

- **Kompromisstext des Ratsvorsitzes WK 14487/26 ADD 1, 21. Sept. 2026**